

LAB 07

FinTechX - Segregation of Duties

Zorluk: İleri • Tahmini süre: 30-60 dakika • Rolünüz: IT Risk Manager

1. HİKÂYE

Sektör Kurumsal finans platformu	Ölçek 640 çalışan
Sistemler LedgerPro, ödeme motoru, Oracle DB, CI/CD	Kapsam İşlem, onay, geliştirme ve DBA yetkileri

FinTechX hızlı büyüme döneminde ekiplerin işlerini aksatmamak için geniş roller tanımlamıştır. Finans Direktörü, küçük ekiplerde katı görevler ayrılığının operasyonu yavaşlatacağını savunur. Yakın zamanda bir kullanıcı aynı gün içinde tedarikçi kaydı oluşturmuş ve 280.000 TL ödeme onaylamıştır; işlem meşrudur ve şirket zararı oluşmamıştır. Risk Komitesi sizden rol tasarımı ve telafi edici kontrolleri incelemenizi istemiştir.

2. SİZE VERİLEN GÖREV

SoD çatışmalarını yalnızca listelemek yerine gerçek yetki, kullanım, iş gerekçesi ve telafi edici kontrollerle birlikte değerlendirin. Her teknik kombinasyonun aynı risk seviyesinde olmadığını dikkate alın.

3. OLAYLAR VE KANITLAR

E-01 | Rol matrisi
AP_CLERK tedarikçi ve ödeme oluşturur; AP_MANAGER ödeme onaylar; FIN_ADMIN rol ve limit değiştirir. 11 kullanıcıda AP_CLERK+AP_MANAGER, 3 kullanıcıda üç rol birlikte vardır.

E-02 | İşlem analizi
Çatışmalı 11 kullanıcının altısı son 90 günde her iki fonksiyonu kullanmıştır. Dört kullanıcı yalnızca oluşturma yapmıştır. Bir hesap doğum iznindeki çalışanın yerine geçici yetkilidir; bitiş tarihi tanımlanmamıştır.

E-03 | Geliştirici erişimi
Sekiz geliştirici production deployment yapabilir. Pipeline onayı ekip lideri tarafından verilir. Acil hata düzeltmelerinde geliştirici kendi merge request'ini onaylayabilmektedir; aylık log review Operasyon tarafından yapılır.

E-04 | DBA faaliyeti
DBA'lar performans loglarını ve audit tablolarını yönetebilir. İki DBA audit kayıtlarını purge edebilir. Purge işlemleri ticket'a bağlıdır; geçen ayki üç purge kaydından birinin ticket numarası geçersizdir.

LAB 07

FinTechX - Segregation of Duties

Zorluk: İleri • Tahmini süre: 30-60 dakika • Rolünüz: IT Risk Manager

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | Telafi edici kontrol

Finans, günlük 100.000 TL üzeri ödemeleri CFO raporuyla inceler. Olaydaki 280.000 TL ödeme raporda görülmüş ve ticari belgeyle doğrulanmıştır. 100.000 TL altındaki bölünmüş işlemler için analiz yoktur.

E-06 | Yönetici açıklaması

'Kimse kendi yaptığı işlemi kötü niyetle onaylamaz; ekibimiz güvenilir. Sistem değişikliği altı ay sürecek. O zamana kadar aylık review yeterli.'

E-07 | Erişim talep örneği

Seçilen 15 yüksek yetkili kullanıcıdan 13'ünde yönetici onayı vardır. İki eski talep e-posta ile verilmiştir. Rol açıklamaları ve risk sahipleri güncel değildir.

4. ÖĞRENCİNİN GÖREVLERİ

- Gerçekleşen ve potansiyel SoD çatışmalarını ayırın.
- İşlem tutarı, kullanım ve telafi edici kontrollerle riskleri derecelendirin.
- Geliştirici production erişim modelini değerlendirin.
- DBA'nın kendi izlerini silebilmesi riskinde ek kanıtları belirleyin.
- Küçük ekip gerekçesine uygulanabilir kontrol alternatifleri geliştirin.
- Günlük CFO review kontrolünün kapsam ve hassasiyetini test edin.
- Risk Komitesine aşamalı iyileştirme planı sunun.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- SoD çatışma matrisi
- Kullanım temelli risk sıralaması
- Telafi edici kontrol değerlendirmesi
- 1 profesyonel audit observation
- 30/60/90 günlük aksiyon planı

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com
adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası